# TASK 1: INITIAL VULNERABILITY ASSESSMENT

TS Academy Cybersecurity Capstone Project | HanTech

## 1. Purpose and approach

The purpose of this task was to identify potentially vulnerable services running on the Metasploitable 2 virtual machine. I used Nmap from the Kali Linux machine to check which TCP ports were open and to identify the services and version information that the target made available. This was an initial discovery exercise. An open port or an old-looking version does not, by itself, prove that a system can be exploited, so the findings below are treated as potential vulnerabilities that need further verification.

## 2. Scan details and main observations

| Item | Observation |
|---|---|
| Target reported by Nmap | 192.168.43.12 |
| Target status | Host was up; reported latency was approximately 0.00070 seconds. |
| Ports scanned | Nmap's default top 1,000 TCP ports. |
| Open ports | 23 open TCP ports were listed in the supplied scan output. |
| Closed ports | 977 closed TCP ports were reported. |
| Scan duration | Approximately 67.57 seconds. |
| Nmap version | 7.99 (as checked on the Kali machine). |

The scan identified several services that deserve attention, including FTP, Telnet, a bind shell, an IRC service, and another FTP service. The target address shown in the scan is 192.168.43.12. This report uses that address because it is the address in the scan output supplied for this task.

## 3. Five potential vulnerabilities identified

### Finding 1 – Potential vsftpd 2.3.4 backdoor (FTP, TCP port 21)

The scan identified vsftpd version 2.3.4 on port 21. This version is associated with a historically backdoored distribution (CVE-2011-2523). If the running binary is the affected backdoored build, an attacker could potentially trigger the backdoor and obtain unauthorised command access. The scan banner alone does not confirm that the affected build is installed, so the exact package/build should be checked before recording this as a confirmed CVE.

### Finding 2 – Unencrypted remote login through Telnet (Telnet, TCP port 23)

Telnet was found listening on port 23. Telnet does not protect login credentials or session data with encryption. If it is used for remote administration across a network, someone able to monitor that network traffic may be able to read usernames, passwords, or commands. An attacker's goal could be to capture credentials and use them to access the machine. The scan confirms that Telnet is exposed; it does not show whether anyone has successfully logged in.

### Finding 3 – Exposed bind shell (bind shell, TCP port 1524)

Nmap identified port 1524 as a bind shell and described it as a "Metasploitable root shell." A bind shell is a service that can provide a command-line session over the network. If this service is reachable and grants the level of access indicated by the scan, it represents a serious exposure because an unauthorised user may be able to obtain high-privilege access. An attacker's goal would be to gain control of the system. This finding should be verified only within the isolated training lab.

### Finding 4 – Potentially vulnerable UnrealIRCd service (IRC, TCP port 6667)

An UnrealIRCd service was found listening on port 6667. Certain UnrealIRCd 3.2.8.1 distributions were affected by a known malicious backdoor (CVE-2010-2075). However, the supplied Nmap output identifies the product name

but does not provide its exact version or build. For that reason, the backdoor is a potential issue to investigate, not a confirmed vulnerability from this scan alone. If an affected build is present, an attacker could seek unauthorised command execution.

### Finding 5 – Legacy ProFTPD service (FTP, TCP port 2121)

A second FTP service was identified on port 2121, with the banner reporting ProFTPD 1.3.1. This is an old software version and should be checked against the vendor's security advisories and the exact package build in use. Older FTP services can expose systems to known software flaws or insecure configuration. A potential attacker goal could be to access files without authorisation or exploit a flaw to gain further access. The scan does not identify a specific CVE for this ProFTPD installation, so no particular exploit is claimed here.

## 4. Summary

The initial Nmap scan shows that the Metasploitable 2 machine is running a number of network services, some of which are associated with known security weaknesses or unsafe configurations. The most concerning observation at this stage is the bind shell reported on port 1524, because the scan describes it as a root shell. Telnet is also a clear security concern where it is used for remote access because it does not encrypt the session. The vsftpd and UnrealIRCd banners warrant careful version/build verification, while ProFTPD 1.3.1 should be checked against reliable vendor and CVE information.

These five items are initial findings for Task 1. The next step is to verify the relevant service details using safe, non-invasive checks in the isolated lab. Risk ratings, CVSS references, and recommended controls will be addressed in the later tasks rather than being assumed from this discovery scan.

## 5. Evidence

The following screenshot is the primary evidence for this assessment. It shows the complete Nmap scan command and output used for this task, including:

- The exact command executed: `nmap -sV -oN task-nmap.txt 192.168.43.12`
- Target IP address confirmed as **192.168.43.12**
- Host status (up) and latency
- All 23 open TCP ports with service names and version banners
- MAC address and OS detection information
- Scan completion time and Nmap version

The original scan output was also saved to the file `task-nmap.txt` on the Kali desktop as additional supporting evidence. The screenshot below matches the findings described in this report.

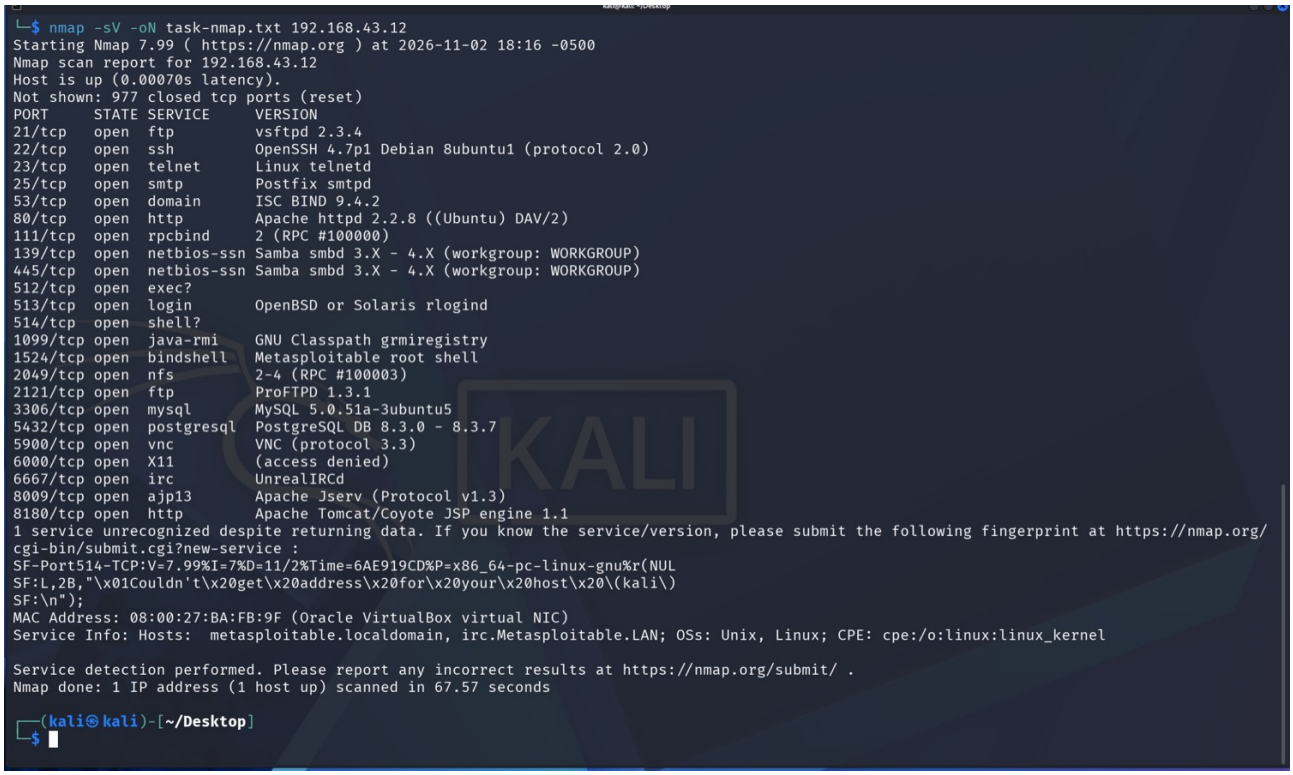



*Figure 1 – Nmap service version scan output for 192.168.43.12 (Kali Linux)*